

Incident Investigation Report

- Koi Stealer Infection — Host 172.17.0.99
- Incident Information
- Executive Summary
- Victim Details
- Alert Summary
- Environment
- Investigation Methodology
- Investigation Findings
- Indicators of Compromise (IOCs)
- Timeline
- Evidence Summary
- MITRE ATT&CK Mapping
- Impact Assessment
- Recommendations
- Conclusion
- Appendix — Evidence Screenshots

← [Back to portfolio home](#)

Incident Investigation Report

Koi Stealer Infection — Host 172.17.0.99

 [Download PDF version](#)

Note on evidence: The IOC and C2 details in this report are corroborated against the alert set published for this exercise (malware-traffic-analysis.net, 2024-09-04). Host, MAC, hostname, username, and full-name identification below are backed by the analyst's own Wireshark review of the capture (see Appendix).

Incident Information

Field	Value
Incident ID	SOC-2024-09-04-001
Incident Type	Koi Stealer Infection (credential/information-stealing malware)
Severity	High
Detection Source	IDS Signature Alerts (Suricata ET/ETPRO ruleset)
Analyst	Lakshmeesh R
Date Investigated	04-Sep-2024
Evidence Source	2024-09-04-traffic-analysis-exercise.pcap
Tool Used	Wireshark

Executive Summary

As early as **Wednesday 2024-09-04 at 17:35 UTC**, a Windows workstation used by **Andrew Fletcher** showed signs of infection with **Koi Stealer**, an information-stealing malware family. IDS alerts flagged repeated outbound HTTP POST traffic from the host to an external IP address, matching a known Koi Stealer command-and-control (C2) check-in signature. No delivery mechanism (e.g., malicious attachment, drive-by download) is confirmed within this

capture — the infection was already underway when alerting began. Separately, HTTPS traffic to a domain independently associated with Koi Loader/Koi Stealer campaigns was also observed from the network, which may be related to this infection but is not conclusively tied to it by the pcap alone.

Victim Details

Field	Value
Host name	DESKTOP-RNVO9AT
IP address	172.17.0.99
MAC address	18:3d:a2:b6:8d:c4
Windows user account name	afletcher
Name of victim	Andrew Fletcher

Alert Summary

Src IP:Port	Dest IP:Port	Alert	Count
172.17.0.99:49813	79.124.78.197:80	ETPRO TROJAN Win32/Koi Stealer CnC Checkin (POST) M2	48

IDS alerts are grouped by destination IP/port; the source port shown (49813) reflects only the first alert in the group — the full 48-alert group originates from 172.17.0.99 across several different ephemeral source ports, all directed at the same external C2 host on port 80.

Environment

Item	Value
LAN Segment	172.17.0.0/24
Domain	bepositive.com
AD Environment Name	BEPOSITIVE
Domain Controller	172.17.0.17 (WIN-CTL9XBQ9Y19)
LAN Gateway	172.17.0.1
LAN Broadcast Address	172.17.0.255

Investigation Methodology

The IDS alert queue was reviewed first to identify the affected host and the nature of the flagged activity. The packet capture was then examined in Wireshark to confirm host/user identity and the scope of the C2 traffic:

- Alert triage — grouping alerts by destination IP/port to isolate the single affected internal host and confirm the alert count
- Host/traffic filtering (`ip.addr == 172.17.0.99`) — isolating all DNS, MDNS, LLMNR, NBNS, and directory-service traffic tied to the host, and confirming its MAC address from the Ethernet header
- LLMNR filtering — confirming the Windows hostname
- Kerberos filtering (`kerberos.CNameString`) — identifying the authenticated AD user account
- String search on the victim's surname — locating the SAMR

Investigation Findings

1. Infected Windows Client

Field	Value
IP Address	172.17.0.99

Evidence: The IDS alert group for ETPRO TR0JAN Win32/Koi Stealer CnC Checkin (POST) M2 consistently originates from **172.17.0.99**, confirmed against the underlying HTTP POST traffic in the capture directed at the external C2 host. Filtering the capture on ip.addr == 172.17.0.99 isolates the full set of DNS, MDNS, LLMNR, NBNS, CLDAP, and LDAP traffic associated with this host, confirming it as the consistent source across all activity reviewed. (See Figure 1.)

2. MAC Address

Field	Value
MAC Address	18:3d:a2:b6:8d:c4

Evidence: The Ethernet frame headers for traffic sourced from 172.17.0.99 identify the hardware address as **18:3d:a2:b6:8d:c4** — visible in the expanded Ethernet II layer (Src: Intel_b6:8d:c4) on the same filtered view used to identify the host's IP address. (See Figure 1.)

3. Hostname

Field	Value
Hostname	DESKTOP-RNVO9AT

Evidence: Filtering on llmnr surfaces a Link-Local Multicast Name Resolution query from **172.17.0.99**, sourced from MAC **18:3d:a2:b6:8d:c4**, resolving the Windows hostname as **DESKTOP-RNVO9AT**. (See Figure 2.)

4. User Account

Field	Value
Username	afletcher

Evidence: Filtering on kerberos.CNameString isolates Kerberos AS-REQ/AS-REP/TGS-REP traffic between the workstation (172.17.0.99) and the domain controller (172.17.0.17). The AS-REQ cname field identifies the authenticated client principal as **afletcher**, within the **BEPOSITIVE** realm. (See Figure 3.)

5. User Full Name

Field	Value
Full Name	Andrew Fletcher

Evidence: Searching the capture for “Fletcher” surfaces a SAMR QueryUserInfo response (Info21) between the domain controller and 172.17.0.99, in which the account’s Full Name field resolves to **Andrew Fletcher**, tying the Kerberos-authenticated account aflletcher to a full identity. (See Figure 4.)

6. Command-and-Control (C2) Traffic

The infected host issued repeated HTTP POST requests to **79.124.78.197:80**, matching a known Koi Stealer C2 check-in pattern:

- POST /foots.php
- POST /index.php?id&subid=qI0uKk7U
- POST /index.php

These requests total 48 alerts in the IDS queue, consistent with a persistent stealer check-in/exfiltration beacon rather than a single event.

7. Possibly Related Activity — Unconfirmed

HTTPS traffic to **www.bellantonicioccolato.it** is also present in this capture. This domain has been independently associated with Koi Loader / Koi Stealer campaigns in public sandbox and threat-intelligence write-ups, and the site itself appears to be a legitimate business site that was likely compromised and repurposed for malware delivery rather than being malicious by design.

This association is not independently confirmed by the pcap alone — there is no direct evidence in the capture (such as a redirect chain or file transfer) linking this HTTPS traffic to the C2 activity above. It is included here as a **likely/probable** indicator, not a confirmed one, and should be treated with that caveat in any downstream action.

No delivery mechanism (email attachment, drive-by download, trojanized installer, etc.) for the initial infection is confirmed within this capture.

Indicators of Compromise (IOCs)

IOC Type	Value	Confidence
Internal Host	172.17.0.99	Confirmed
MAC Address	18:3d:a2:b6:8d:c4	Confirmed
Hostname	DESKTOP-RNVO9AT	Confirmed
Username	aflletcher	Confirmed
Full Name	Andrew Fletcher	Confirmed
Koi Stealer C2 IP	79.124.78.197:80	Confirmed
C2 URI	/foots.php	Confirmed
C2 URI	/index.php?id&subid=qI0uKk7U	Confirmed
C2 URI	/index.php	Confirmed
Possibly related domain	www.bellantonicioccolato.it (HTTPS)	Likely / unconfirmed
Malware binary SHA256	Not recovered from this capture	N/A

Timeline

Time (UTC)	Event
≤ 17:35	Earliest observed sign of Koi Stealer infection on 172.17.0.99
17:35 onward	Repeated POST C2 checkins to 79.124.78.197:80 (48 alerts total in the reviewed alert set)

(The capture does not establish a confirmed initial-access timestamp — 17:35 UTC marks the earliest point at which infection indicators are visible in the alert/traffic data reviewed.)

Evidence Summary

Evidence	Protocol / Method	Figure
IP and MAC identification	DNS/MDNS/LLMNR/NBNS/CLDAP correlation + Ethernet header	Figure 1
Hostname discovery	LLMNR	Figure 2
User authentication	Kerberos (AS-REQ CNameString)	Figure 3
Full user identity	SAMR (QueryUserInfo)	Figure 4
C2 confirmation	HTTP POST beaconing, IDS trojan signature (Koi Stealer CnC Checkin)	—
Possibly related activity	HTTPS traffic to a domain independently linked to Koi Loader/Stealer campaigns	—

MITRE ATT&CK Mapping

Technique	ID	Notes
Application Layer Protocol: Web Protocols	T1071.001	C2 checkin conducted over repeated HTTP POST requests
Exfiltration Over C2 Channel	T1041	Stealer-family malware typically exfiltrates data via its C2 checkin channel; not independently confirmed by request content in this capture
Credentials from Password Stores	T1555	Typical behavior for Koi Stealer as a credential-stealing malware family; not independently confirmed by capture content
Data from Local System	T1005	Typical stealer behavior (harvesting local files/browser data); not independently confirmed by capture content

Note on initial access: No technique is mapped for initial access (e.g., T1189 Drive-by Compromise, T1566 Phishing) because this capture does not confirm how the host was infected. The HTTPS traffic to www.bellantonicioccolato.it is a plausible lead but not conclusive.

Impact Assessment

Host **172.17.0.99 (DESKTOP-RNVO9AT)**, used by domain account **afletcher (Andrew Fletcher)**, exhibited a sustained C2 check-in pattern (48 alerts) consistent with an active Koi Stealer infection. Stealer malware of this type is generally designed to harvest credentials, browser-stored data, and other local system information and exfiltrate it via its C2 channel — meaning the practical risk here extends beyond the endpoint itself to **any credentials or session data stored on that machine at the time of infection**, including potentially the afletcher domain account and any personal or third-party account credentials saved in the browser.

Because the initial access vector is not confirmed in this capture, it is not possible to determine from network evidence alone whether this was a targeted delivery, a driveby/compromised-site download, or another vector — this needs endpoint-level (EDR/host forensics) follow-up.

Recommendations

Immediate

- **Isolate the endpoint:** quarantine 172.17.0.99 via EDR network isolation or switch-port shutdown to halt further C2 communication.
- **Block the C2 indicator:** block **79.124.78.197** and the specific URI patterns (/foots.php, /index.php) at the firewall/proxy.
- **Force credential resets:** reset the afletcher domain account password, and treat any credentials stored in that user's browser profile as compromised — stealer malware commonly targets saved browser credentials, cookies, and autofill data.
- **Forensic capture:** collect memory/disk images from the host to recover the malware binary (for hashing and sandbox analysis) and to determine the actual initial access vector.

Long-Term

- Investigate whether **www.bellantonicioccolato.it** traffic correlates with this infection on the host or other hosts on the network, using proxy/DNS logs alongside public threat-intel write-ups for Koi Loader/Stealer campaigns.
 - Deploy or tune detections for the specific Koi Stealer C2 URI patterns identified here, since C2 IPs for stealer families often rotate faster than domains.
 - Review credential-hygiene policy for any accounts that may have been active on this host, including non-corporate accounts saved in the browser.
 - If the host is a laptop or otherwise used outside the monitored network, review remote/BYOD security controls, since infections of this kind often originate off-network (e.g., a user's home environment) before returning to the corporate LAN.
-

Conclusion

The investigation confirmed that Windows workstation **172.17.0.99 (DESKTOP-RNVO9AT)**, MAC **18:3d:a2:b6:8d:c4**, used by domain account **afletcher (Andrew Fletcher)**, was infected with **Koi Stealer**, evidenced by a sustained pattern of C2 check-in traffic (48 IDS alerts) to **79.124.78.197:80**. LDAP and host/endpoint correlation confirmed the affected asset and user identity. The initial infection vector remains unconfirmed from network evidence alone; HTTPS

traffic to a domain independently associated with Koi Loader/Stealer campaigns was observed and should be treated as a probable — but not conclusively confirmed — related indicator. The recommendations above, particularly credential resets and endpoint forensics, should be actioned promptly given the credential-theft focus of this malware family.

Appendix — Evidence Screenshots

Figure 1. Filtered view (ip.addr == 172.17.0.99) showing the full range of DNS, MDNS, LLMNR, NBNS, and directory-service traffic associated with the infected host. The expanded Ethernet II layer on the selected frame confirms the source MAC address (18:3d:a2:b6:8d:c4) alongside the host's IP (172.17.0.99).

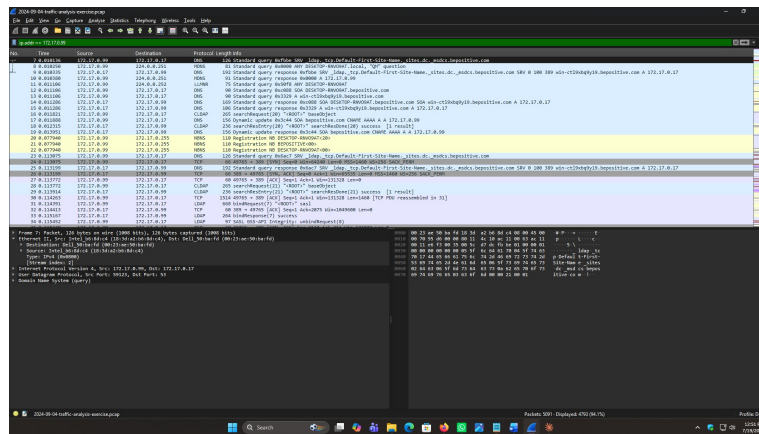


Figure 1

Figure 2. LLMNR query traffic (llmnr filter) from 172.17.0.99 resolving hostname DESKTOP-RNVO9AT.

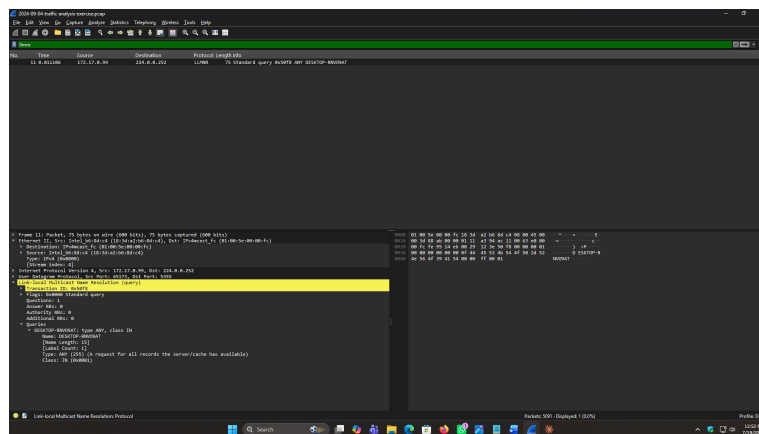


Figure 2

Figure 3. Kerberos AS-REQ traffic (kerberos.CNameString filter) identifying authenticated client principal afletcher within the BEPOSITIVE realm.

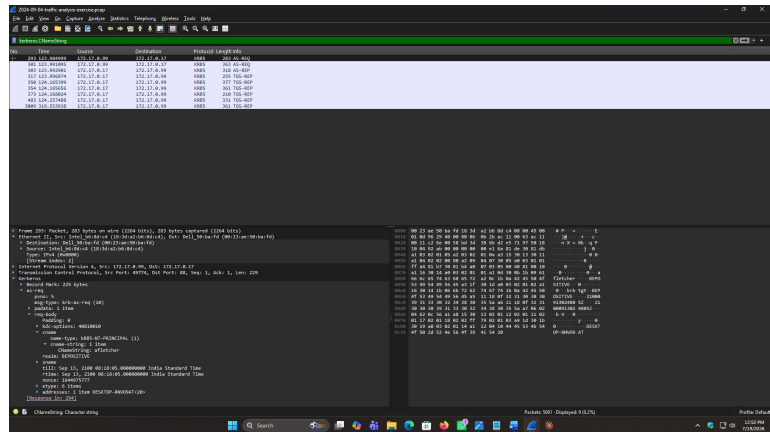


Figure 3

Figure 4. SAMR QueryUserInfo response (Info21), located via a string search on the victim’s surname, resolving account afletcher to full name “Andrew Fletcher”.

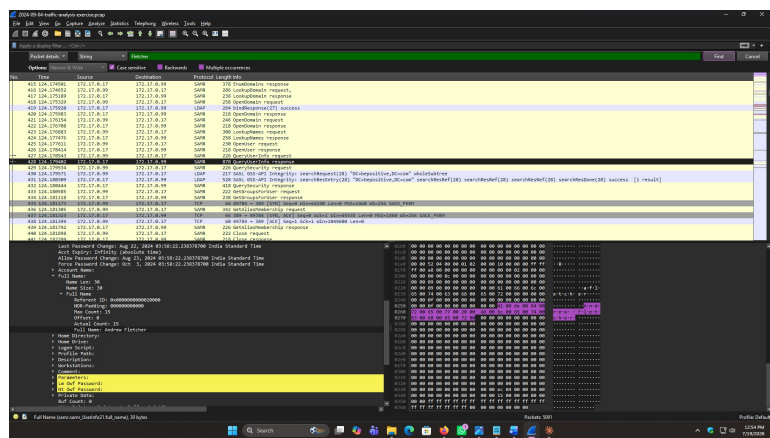


Figure 4

Report prepared by Lakshmeesh R as part of a SOC investigation portfolio exercise. Investigation based on a public packet capture and alert set published by malware-traffic-analysis.net (2024-09-04 traffic analysis exercise).